

Potential buffer-overflow from string operations in function `array_from_pyobj` of `fortranobject.c` #19000

Closed

#20630

awen-li opened on May 13, 2021

Reproducing code example:

Snippet:

```
char mess[200];
if ((intent & F2PY_INTENT_HIDE)
    || ((intent & F2PY_INTENT_CACHE) && (obj==Py_None))
    || ((intent & F2PY_OPTIONAL) && (obj==Py_None))
) {
    /* intent(cache), optional, intent(hide) */
    if (count_negative_dimensions(rank,dims) > 0) {
        int i;
        strcpy(mess, "failed to create intent(cache|hide)|optional array"
            "-- must have defined dimensions but got (");
        for(i=0;i<rank;++i)
            sprintf(mess+strlen(mess),"%s NPY_INTP_FMT ",",",dims[i]);
        strcat(mess, ")");
        PyErr_SetString(PyExc_ValueError,mess);
        return NULL;
    }
    arr = (PyArrayObject *)
        PyArray_New(&PyArray_Type, rank, dims, type_num,
            NULL, NULL, 1,
            !(intent&F2PY_INTENT_C),
            NULL);
    if (arr==NULL) return NULL;
    if (!(intent & F2PY_INTENT_CACHE))
        PyArray_FILLWBYTE(arr, 0);
    return arr;
}
```

Error message:

File: numpy/f2py/src/fortranobject.c**Function:** `array_from_pyobj` (line 724 : 733)**Optional call-path:** External -> `fortran_setattr` -> `array_from_pyobj`**Details in** [description](#)

When we run our analysis tool on NumPy, a few inappropriate string operations are reported at call sites of function `strcpy`, `sprintf`, and `strcat` in `array_from_pyobj`. There are no boundary checks at these points despite "mess" seems large enough to ensure the operations safe except for the point shown above. As a suggestion, it is better to replace these functions with `strncpy`, `strncat`, and `snprintf`.

NumPy/Python version information:

the main branch of NumPy

awen-li on Jun 1, 2021

Author ...

Anyone can help confirm this issue? thanks.

 **eric-wieser** added **00 - Bug** **component: num...** on Jun 1, 2021

eric-wieser on Jun 1, 2021

Member ...

This report is almost certainly valid, but I suspect there are lower-hanging bugs in the `f2py` code. It's probably easier to assemble the strings on the heap using the Python C API than mess with keeping track of buffer lengths.

melissawm on Jun 1, 2021

Member ...

Thanks @Daybreak2019 - string support in `f2py` is undergoing some changes, I'll include this in the things to check.

 **HaoZeke** self-assigned this on Aug 27, 2021

00xc on Dec 20, 2021

...

Hi, any update on this issue? It was recently assigned [CVE-2021-41496](#).

 **WarrenWeckesser** added a commit that references this issue on Dec 20, 2021

BUG: `f2py`: Simplify creation of an exception message. Closes [numpygh-.](#) ... ⓘ 271010f

seberg on Dec 20, 2021

Member ...

I don't think the CVE text is quite correct. I do not see the "by carefully constructing an array with negative values" working (I guess "array" refers to the C array of `dims`), these are negative dimensions though and such an array should never exist, there would be far worse problems.

I would have to check closer, but I think that negative values are always placed there by f2py/the wrapping module itself. Users may be able to trigger the error (not quite sure how), but I do not think they can craft it or the message based on malicious data (the one exception is that there is a test function calling this more directly, but this is also not available by passing malicious data).

To be clear, this should be fixed and should be easy enough (contributions also welcome!). [@melissawm](#), [@HaoZeke](#) do you have a bit of time to just check this off? I still doubt there is much of an attack vector at all, unless you are wrapping very high dimensional working arrays and additionally expose an API that allows "malicious data" to toggle whether or not the path is taken.

2

WarrenWeckesser on Dec 21, 2021

Member ...

[@seberg](#), I submitted a PR a few minutes ago: [#20630](#)

2

seberg on Dec 21, 2021

Member ...

Ah, that was quick, cool :). Not related to this, but we may want to replace all other `sprintf` 's here with `PyErr_Format` or similar, since the f2py-cleanup drive is continuing.

  **charris** closed this as completed in [271010f](#) on Dec 21, 2021

  **charris** added 2 commits that reference this issue on Dec 21, 2021

Merge pull request [#20630](#) from WarrenWeckesser/f2py-possible-strcpy-b. ...

 Verified 7033c36

BUG: f2py: Simplify creation of an exception message. Closes [numpygh-](#). ...

 Verified 856d397

  **charris** mentioned this on Dec 24, 2021

 [BUG: f2py: Simplify creation of an exception message. #20630](#)

4 remaining items

Load more

  **sbrunner** added 14 commits that reference this issue on Feb 2, 2022

Fix CVE ...

0a5772c

Fix CVE ...

e0a9f2c

Fix CVE ...

632fef1

Fix CVE ...

77b10ef

Fix CVE	...	d6c2240
Fix CVE	...	8f1cc41
Fix CVE	...	0bcd811
Fix CVE	...	7b0ebe6
Fix CVE	...	30454e8
Fix CVE	...	c5af071
Fix CVE	...	76cc0b7
Fix CVE	...	a92fb7a
Fix CVE	...	67abe59
Ignore CVE	...	52c40f6



 **dbalchev** added a commit that references this issue on Apr 19, 2022

BUG: f2py: Simplify creation of an exception message. Closes [numpygh-](#).   fdffe62

[Sign up for free](#) to join this conversation on **GitHub**. Already have an account? [Sign in to comment](#)

Assignees

 **HaoZeke**

Labels

00 - Bug

component: numpy.f2py

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development



Code with agent mode



 **BUG: f2py: Simplify creation of an exception message.**

numpy/numpy

Participants

     +2

